

CYB-048 : Sécurité périmétrique et DMZ

Introduction Générale du Cours

La sécurité périmétrique est l'une des disciplines fondatrices de la cybergdéfense. Avant que les architectures Zero Trust, les solutions SASE et le cloud computing ne viennent complexifier le paysage, la protection du système d'information reposait sur un principe simple et puissant : ériger une frontière robuste entre le réseau interne de confiance et le monde extérieur hostile. Cette frontière — le périmètre réseau — reste aujourd'hui un pilier incontournable de toute stratégie de défense en profondeur, même si elle ne peut plus, à elle seule, constituer la totalité de la réponse sécurité d'une organisation.

Au cœur de la sécurité périmétrique se trouve la DMZ — Zone Démilitarisée. Ce concept, emprunté au vocabulaire militaire, désigne la zone tampon interposée entre deux forces antagonistes. En informatique, la DMZ est le réseau intermédiaire qui héberge les services devant être accessibles depuis Internet — serveur web, passerelle e-mail, concentrateur VPN — tout en les isolant du réseau interne privé. Correctement architecturée, la DMZ garantit qu'une compromission d'un service exposé ne se transforme pas automatiquement en compromission du cœur du système d'information.

Ce cours explore en profondeur les principes et les techniques de la sécurité périmétrique moderne : la conception des zones de sécurité et de leur hiérarchie de confiance, les architectures de DMZ adaptées à différents contextes organisationnels, la gestion rigoureuse des flux interzones, le placement et la configuration des services exposés, et les mécanismes de filtrage applicatif complémentaires au pare-feu réseau. Il aborde également les évolutions récentes — cloud hybride, Zero Trust, SASE — qui redéfinissent progressivement les contours du périmètre traditionnel.

Objectifs Pédagogiques du Module

À l'issue de ce cours, l'apprenant doit être capable de :

1. Maîtrise Conceptuelle et Architecturale

- Comprendre le rôle de la sécurité périmétrique dans une stratégie de défense en profondeur.
- Définir les zones de sécurité d'un SI (Internet, DMZ publique, DMZ privée, LAN, Zone serveurs, Zone management, Zone OT) et leurs niveaux de confiance respectifs.
- Distinguer et comparer les architectures de DMZ : un pare-feu, deux pare-feu, hétérogène, cloud hybride.

2. Compétences Techniques et Opérationnelles

- Construire une matrice de flux interzones complète et cohérente avec la politique de sécurité.
- Rédiger et ordonner des règles de filtrage pour un pare-feu périmétrique en respectant le principe du moindre privilège.

- Configurer et positionner correctement les services exposés (reverse proxy, passerelle mail, DNS, VPN, bastion) dans l'architecture DMZ.
- Mettre en œuvre des mécanismes de filtrage applicatif complémentaires : WAF, proxy filtrant, IPS.

3. Expertise en Analyse et Audit

- Identifier les failles courantes d'une architecture périmétrique : flux non documentés, règles trop permissives, services mal positionnés.
- Analyser une architecture existante et proposer des améliorations structurées et priorisées.
- Comprendre les vecteurs d'attaque ciblant le périmètre (pivot depuis la DMZ, DDoS, exploitation de services exposés) et les contre-mesures associées.

4. Évolutions et Conformité

- Appréhender les évolutions du périmètre face au cloud, au télétravail et aux architectures Zero Trust.
- Identifier les exigences réglementaires s'appliquant à la sécurité périmétrique (ISO 27001, NIS2, PCI-DSS).

Chapitre 1 : Fondements de la Sécurité Périmétrique

1. Le Modèle du Périmètre — Origines et Principes

Le modèle de sécurité périmétrique repose sur une analogie simple et intuitive : le château fort médiéval. Les murailles, les douves et les tours de guet constituent le périmètre défensif ; tout ce qui se trouve à l'intérieur est considéré comme sûr, tout ce qui est à l'extérieur est hostile. Traduit en informatique, ce modèle définit un réseau interne de confiance (le LAN), séparé du monde extérieur (Internet) par des équipements de sécurité périmétrique — pare-feu, IPS, proxy — dont la mission est de contrôler rigoureusement tout ce qui franchit la frontière.

Ce modèle a constitué la colonne vertébrale de la sécurité informatique pendant trois décennies et reste fondamental aujourd'hui, même si ses limites ont été mises en évidence par l'évolution des menaces. Son principal apport est la défense en profondeur : en concentrant les contrôles aux points de passage obligatoires entre les zones, il maximise la visibilité sur les flux et minimise les vecteurs d'attaque accessibles depuis l'extérieur. Sa principale limite est l'hypothèse de confiance implicite accordée au trafic interne : dès lors qu'un attaquant franchit le périmètre — via un phishing, une vulnérabilité d'un service exposé ou une clé USB — il évolue souvent sans entrave dans un réseau interne peu segmenté.

2. Le Concept de Zones de Sécurité

La sécurité périmétrique moderne ne se limite pas à une frontière unique entre dedans et dehors. Elle s'organise en zones de sécurité multiples, chacune définie par un niveau de

confiance et des politiques d'accès spécifiques. Ce zonage est le socle de toute architecture réseau sécurisée : il permet d'appliquer le principe du moindre privilège au niveau réseau — chaque système ne peut communiquer qu'avec les zones et les services dont il a strictement besoin pour fonctionner.

Le tableau suivant présente les zones de sécurité standard d'une architecture d'entreprise, avec leurs niveaux de confiance et leurs politiques d'accès caractéristiques :

Zone	Niveau de confiance	Exemples de systèmes	Politique d'accès
Internet (WAN)	Nul — zone hostile par définition	Clients externes, partenaires, attaquants	Aucun accès direct vers le LAN ou les serveurs internes
DMZ publique	Faible — systèmes exposés	Serveur web, reverse proxy, passerelle mail, DNS externe	Accessible depuis Internet sur ports autorisés ; accès vers LAN strictement interdit
DMZ privée	Modéré — services internes semi-exposés	Serveur de fichiers partenaires, API B2B, bastion SSH	Accessible depuis LAN et partenaires identifiés ; accès vers LAN filtré
LAN (réseau interne)	Élevé — réseau des utilisateurs	Postes de travail, imprimantes, téléphonie IP	Accès sortant autorisé (proxy) ; accès entrant depuis Internet interdit
Zone serveurs	Élevé — applications critiques	ERP, bases de données, AD, messagerie interne	Accessible uniquement depuis LAN sur ports applicatifs ; accès depuis DMZ restreint
Zone management	Très élevé — administration	Bastion, consoles d'administration, SIEM	Accessible uniquement depuis postes d'administration identifiés ; accès depuis Internet interdit
Zone OT / SCADA	Critique — isolée	Automates industriels, SCADA, capteurs IoT	Isolée du LAN ; échanges via diode de données unidirectionnelle si nécessaire

Cette hiérarchie de zones n'est pas figée : elle s'adapte au contexte de chaque organisation. Une entreprise industrielle ajoutera une zone OT/SCADA strictement isolée. Une organisation ayant des partenaires commerciaux intégrés disposera d'une zone partenaires avec des règles d'accès spécifiques. Une entreprise hébergeant des données de santé devra intégrer une zone dédiée aux systèmes de santé conformément aux exigences HDS. Le principe fondateur reste constant : chaque zone est séparée des autres par des contrôles d'accès explicites, et l'accès entre zones n'est accordé qu'après justification fonctionnelle documentée.

3. Le Principe de Defense in Depth

La défense en profondeur (Defense in Depth) est la stratégie de sécurité qui sous-tend l'ensemble de l'architecture périmétrique. Elle postule qu'aucune mesure de sécurité n'est infaillible, et que la protection réelle provient de la superposition de plusieurs couches de

défense indépendantes. Si un attaquant franchit la première couche (par exemple, en exploitant une vulnérabilité d'un service DMZ), il est confronté à une deuxième couche (le pare-feu interne qui bloque tout flux de la DMZ vers le LAN) avant de pouvoir progresser vers les actifs critiques.

Dans le contexte périmétrique, les couches de défense typiques sont : le filtrage réseau périmétrique (pare-feu stateful), le filtrage applicatif (WAF, proxy, inspection de contenu), la détection d'intrusion (IPS/IDS en coupure ou en écoute), la segmentation interne (VLAN, micro-segmentation), l'authentification renforcée aux points d'accès (MFA, bastion), et la supervision continue (SIEM, logs de flux). Chaque couche est conçue pour être efficace même si la couche précédente a été contournée.

Chapitre 2 : La Zone Démilitarisée — Conception et Architecture

1. Définition et Rôle de la DMZ

La DMZ (DeMilitarized Zone) est le réseau intermédiaire entre Internet et le réseau interne privé, hébergeant les services devant être accessibles depuis l'extérieur tout en protégeant le réseau interne d'une compromission directe. Son principe fondateur est simple : si un service exposé en DMZ est compromis par un attaquant, celui-ci se retrouve dans une zone isolée, sans accès direct au réseau interne. Il doit franchir un second niveau de contrôle — le pare-feu interne ou les règles de filtrage entre DMZ et LAN — pour progresser vers les actifs critiques.

La DMZ répond à une exigence fonctionnelle incontournable : certains services doivent être accessibles depuis Internet pour que l'organisation puisse fonctionner (site web, e-mail, accès VPN distant). Ne pas les exposer est impossible ; les exposer directement sur le réseau interne est inacceptable du point de vue de la sécurité. La DMZ est la solution architecturale qui réconcilie ces deux impératifs contradictoires en créant un espace d'exposition contrôlé et isolé.

2. Architectures de DMZ — Comparatif

Plusieurs architectures de DMZ sont possibles, chacune offrant un niveau de protection et une complexité de gestion différents. Le choix entre elles dépend du niveau de criticité des actifs à protéger, du budget disponible et de la maturité de l'équipe technique. Le tableau suivant présente les quatre architectures principales :

Architecture	Description	Avantages	Inconvénients
DMZ à un pare-feu	Un seul pare-feu multi-interface (WAN, DMZ, LAN)	Simple, économique, adapté aux petites structures	Point de défaillance unique ; compromission du pare-feu = compromission totale

DMZ à deux pare-feu (sandwich)	Deux pare-feu distincts encadrant la DMZ (FW externe + FW interne)	Défense en profondeur réelle ; compromission d'un FW ne suffit pas	Plus coûteux, gestion plus complexe, latence légèrement accrue
DMZ avec pare-feu différents (hétérogène)	Deux pare-feu de constructeurs différents (ex : Fortinet + pfSense)	Élimine le risque d'exploitation d'une même CVE sur les deux équipements	Compétences doubles requises, maintenance plus lourde
DMZ cloud hybride	Services exposés dans le cloud (AWS WAF, Azure Front Door) + réseau interne on-premise	Scalabilité, protection DDoS native, répartition géographique	Dépendance cloud, complexité des flux hybrides, visibilité réduite sans CASB

3. Architecture à Deux Pare-feu — Architecture de Référence

L'architecture à deux pare-feu, souvent appelée architecture en sandwich, est la référence en matière de DMZ sécurisée. Elle positionne la DMZ entre deux pare-feu distincts : le pare-feu externe (FW1) filtre le trafic entre Internet et la DMZ, n'autorisant que les flux légitimes vers les services exposés (HTTPS vers le reverse proxy, SMTP vers la passerelle mail, etc.) ; le pare-feu interne (FW2) filtre le trafic entre la DMZ et le réseau interne, autorisant uniquement les flux applicatifs stricts nécessaires (par exemple, le front-end web en DMZ interrogeant le serveur de base de données interne sur son port applicatif uniquement).

Cette architecture garantit qu'un attaquant ayant compromis un service en DMZ doit contourner le FW2 — un équipement entièrement distinct du FW1 — pour accéder au réseau interne. Si les deux pare-feu sont de constructeurs différents, le risque qu'une même CVE les compromette simultanément est éliminé. La contre-partie est un coût plus élevé (deux licences, deux équipements à maintenir) et une configuration plus complexe à maintenir en cohérence. Pour les organisations dont les actifs internes sont critiques (données financières, données de santé, propriété intellectuelle), cet investissement est pleinement justifié.

4. DMZ Publique vs DMZ Privée

Une architecture mature distingue fréquemment deux zones DMZ de niveaux de confiance différents. La DMZ publique héberge les services directement accessibles depuis Internet, sans authentification préalable : serveur web public, reverse proxy, passerelle e-mail entrant, serveur DNS public, concentrateur VPN. Ces serveurs sont, par définition, exposés aux scans, aux tentatives d'exploitation et aux attaques automatisées permanentes provenant d'Internet.

La DMZ privée héberge des services accessibles uniquement depuis des sources identifiées et authentifiées : partenaires commerciaux avec accès B2B, équipes IT en télétravail via le bastion, serveurs de fichiers d'échange avec des prestataires. Son niveau de confiance est légèrement supérieur à celui de la DMZ publique, mais elle reste strictement isolée du LAN interne. Cette distinction permet d'appliquer des politiques de filtrage plus précises : les accès depuis Internet vers la DMZ privée passent par le bastion ou un VPN, jamais directement.

Chapitre 3 : Gestion des Flux Interzones

1. La Matrice de Flux — Document de Référence

La matrice de flux est le document qui formalise l'ensemble des communications autorisées entre les zones de sécurité. C'est la traduction opérationnelle de la politique de sécurité réseau : chaque ligne de la matrice correspond à un flux autorisé, justifié par un besoin fonctionnel documenté, et chaque flux absent de la matrice doit être interdit par les règles de filtrage. Ce document est à la fois un outil de conception (il guide la rédaction des règles de pare-feu), un outil d'audit (tout flux constaté dans les logs et absent de la matrice est une anomalie à investiguer) et un outil de communication (il rend la politique de sécurité réseau compréhensible par les équipes IT et métier).

Le tableau suivant présente une matrice de flux de référence pour une architecture périmétrique standard avec DMZ :

Source	Destination	Protocole/Port	Autorisation	Justification
Internet	DMZ — Reverse proxy	TCP/443 HTTPS	Autorisé	Accès web public des utilisateurs externes
Internet	DMZ — Passerelle mail	TCP/25 SMTP	Autorisé (filtré)	Réception des e-mails entrants via antispam
Internet	LAN ou Zone serveurs	Tout	Interdit	Aucun accès direct depuis Internet vers le réseau interne
DMZ	Zone serveurs — Back-end	TCP/8080, TCP/5432	Autorisé (restreint)	Le front-end DMZ interroge le back-end applicatif sur port applicatif uniquement
DMZ	LAN	Tout	Interdit	Isolation stricte : une DMZ compromise ne doit pas atteindre le LAN
LAN	Internet	TCP/443 HTTPS	Autorisé (proxy)	Navigation web des utilisateurs via proxy filtrant
LAN	Zone serveurs	TCP/applicatif	Autorisé (filtré)	Accès des postes aux applications métier sur ports définis
LAN	DMZ	Tout	Interdit par défaut	Les utilisateurs internes n'ont pas à accéder directement aux serveurs DMZ
Zone management	Toutes zones	TCP/22, TCP/3389, SNMP	Autorisé (restreint)	Administration des équipements depuis le réseau de gestion dédié

2. Principes de Rédaction des Règles de Filtrage

La rédaction des règles de pare-feu est un exercice de précision qui détermine directement le niveau de sécurité de l'architecture. Plusieurs principes fondamentaux doivent guider cet exercice. Le principe du moindre privilège est le plus important : n'autoriser que le strict minimum nécessaire au fonctionnement des services. Une règle autorisant tout le trafic TCP entre la DMZ et le serveur de base de données interne, alors que seul le port 5432 (PostgreSQL) est nécessaire, expose inutilement l'ensemble des ports TCP du serveur.

Le principe du deny-all par défaut impose que toute règle de filtrage se termine par une règle explicite qui bloque tout trafic non couvert par les règles précédentes. Cette règle implicite — ou explicite dans les bonnes pratiques — doit également générer un log : les connexions bloquées par la règle finale sont précieuses pour détecter des tentatives d'accès non autorisées ou des flux mal configurés. Le principe de spécificité maximale impose que chaque règle soit aussi précise que possible : adresse IP source précise plutôt qu'un sous-réseau entier, port de destination précis plutôt qu'une plage, protocole exact (TCP ou UDP, pas les deux) quand le service n'en utilise qu'un.

3. Exemple de Jeu de Règles Pare-feu

Le tableau suivant présente un exemple de politique de filtrage périmétrique ordonné, applicable sur un pare-feu en coupure entre Internet, la DMZ et le LAN interne. L'ordre des règles est fondamental : un pare-feu stateful applique les règles dans l'ordre et s'arrête à la première correspondance :

N°	Source	Destination	Port/Proto	Action	Log	Commentaire
1	Any	DMZ-WebSrv (80.x.x.10)	TCP/443	Permit	Oui	HTTP S public
2	Any	DMZ-Mail (80.x.x.11)	TCP/25	Permit	Oui	SMT P entra nt
3	DMZ	LAN 192.168.0.0/16	Any	Deny	Oui	Isolati on DMZ →LA N
4	DMZ-WebSrv	SRV-App 10.0.1.5	TCP/8080	Permit	Oui	Front →Ba ck
5	LAN	Internet	TCP/443	Permit	Oui	Web via proxy

6	LAN	Internet	TCP/80	Deny	Oui	HTTP interd it
7	Bastion	All zones	TCP/22	Permit	Oui	SSH admi n
8	Any	Any	Any	Deny	Oui	Règle implic ite finale

Cet exemple illustre plusieurs bonnes pratiques. Les règles les plus spécifiques (autorisant des flux précis) précèdent les règles génériques de refus. Chaque règle autorisante génère un log. La règle 3 (Deny DMZ vers LAN) est une règle de sécurité fondamentale qui protège le réseau interne d'un pivot depuis la DMZ. La règle 8 (Deny All) est la règle de refus finale explicite qui bloque et journalise tout trafic ne correspondant à aucune règle précédente. L'annotation de chaque règle avec un commentaire fonctionnel est indispensable pour la maintenabilité.

4. Journalisation et Supervision des Flux

La journalisation des flux réseau est le mécanisme qui donne de la visibilité sur ce qui traverse le périmètre. Sans logs de flux, le pare-feu est un filtre aveugle : on sait qu'il applique des règles, mais on n'a aucune visibilité sur ce qui tente de les contourner. Les logs de flux doivent être transmis en temps réel vers le SIEM pour corrélation avec les autres événements de sécurité.

La journalisation ne doit pas se limiter aux flux bloqués. Les flux autorisés, particulièrement ceux entre la DMZ et le réseau interne, sont tout aussi importants à surveiller : un pic de volume sortant depuis le serveur web DMZ vers une IP externe inconnue peut indiquer une exfiltration de données depuis un serveur compromis. Des solutions comme NetFlow, IPFIX ou les journaux de pare-feu enrichis permettent d'analyser les volumes, les destinations et les fréquences des flux pour détecter des comportements anormaux que les règles de filtrage ne bloquent pas (car le flux est techniquement autorisé mais son comportement est suspect).

Chapitre 4 : Services en DMZ — Placement et Sécurisation

1. Principes de Placement des Services

Le placement d'un service dans la bonne zone est une décision architecturale qui a des conséquences directes sur la surface d'attaque de l'organisation. Un service placé trop proche du réseau interne offre une surface d'attaque plus dangereuse en cas de compromission ; un service placé trop loin de ses dépendances internes nécessite des règles de filtrage supplémentaires et plus complexes à sécuriser. Le critère de placement

principal est la nécessité d'exposition : un service qui doit être accessible depuis Internet appartient à la DMZ publique ; un service accessible uniquement à des partenaires identifiés appartient à la DMZ privée ; un service purement interne n'a aucune raison d'être en DMZ.

Le tableau suivant présente les services les plus couramment exposés dans une DMZ, avec leur placement recommandé et les points de sécurité clés associés :

Service	Port standard	Placement recommandé	Points de sécurité clés
Serveur web (Apache, Nginx)	TCP/443	DMZ publique — derrière reverse proxy	TLS 1.2/1.3 uniquement, désactivation des headers serveur, WAF en frontal
Reverse proxy (HAProxy, Nginx)	TCP/443	DMZ publique — frontal de tous les services web	Terminaison TLS, filtrage des en-têtes, limitation de débit, inspection de contenu
Passerelle e-mail (Postfix, Exchange Edge)	TCP/25, 587	DMZ publique — relai entrant et sortant	SPF, DKIM, DMARC, filtrage antispam/antivirus, pas d'accès direct au serveur interne
DNS externe (BIND, Unbound)	UDP/53, TCP/53	DMZ publique — zone DNS publique uniquement	Séparation stricte DNS externe (publique) / interne (privée), désactivation récursion publique
VPN SSL/IPsec (endpoint)	UDP/1194, UDP/500	DMZ publique — concentrateur VPN	Authentification MFA, révocation de certificats, segmentation post-authentification
Bastion SSH / RDP (Guacamole, Teleport)	TCP/22, TCP/443	DMZ privée — accès uniquement après authentification forte	MFA obligatoire, enregistrement des sessions, accès limité aux cibles autorisées
API B2B (REST, SOAP)	TCP/443	DMZ privée — partenaires identifiés	Authentification mutuelle TLS (mTLS), limitation de débit, validation des entrées (OWASP)

2. Le Reverse Proxy — Élément Central de la DMZ

Le reverse proxy est le composant architectural qui médiatise toutes les requêtes HTTP/HTTPS entre les clients externes et les serveurs d'application internes ou en DMZ. Son déploiement en frontal de tous les services web est une bonne pratique incontournable : il masque la topologie des serveurs internes (les clients externes voient uniquement l'IP du reverse proxy, jamais celle des serveurs d'application), centralise la terminaison TLS (un seul point de gestion des certificats), et offre un point de contrôle unique pour le filtrage applicatif.

La configuration sécurisée d'un reverse proxy Nginx ou Apache implique plusieurs paramètres critiques. La restriction des protocoles TLS aux versions 1.2 et 1.3 uniquement (TLS 1.0 et 1.1 sont obsolètes et vulnérables). La définition d'une liste de suites cryptographiques robustes, excluant les algorithmes faibles (RC4, DES, MD5). La suppression des en-têtes révélant les technologies serveur (Server: nginx, X-Powered-By: PHP). L'activation des en-têtes de sécurité HTTP : Strict-Transport-Security (HSTS, forçant HTTPS pour tous les futurs accès), Content-Security-Policy (CSP, limitant les sources de scripts pour réduire le risque XSS), X-Frame-Options (prévenant le clickjacking). La

limitation du débit (rate limiting) pour se protéger contre les attaques par force brute ou les tentatives de déni de service applicatif.

3. La Passerelle E-mail — Anti-relayage et Filtrage

La passerelle e-mail est un équipement ou service situé en DMZ publique, servant de point d'entrée et de sortie unique pour tous les e-mails de l'organisation. Son rôle sécurité est triple : filtrer les e-mails entrants (antispam, antivirus, détection de phishing), authentifier les e-mails sortants (SPF, DKIM, DMARC) pour protéger la réputation du domaine, et empêcher le relayage ouvert (open relay) qui transformerait le serveur en outil de spam.

Les mécanismes d'authentification des e-mails sont indispensables pour toute organisation souhaitant protéger son domaine contre l'usurpation. SPF (Sender Policy Framework) est un enregistrement DNS TXT listant les serveurs autorisés à envoyer des e-mails au nom du domaine ; tout e-mail reçu depuis un serveur non répertorié dans le SPF est suspect. DKIM (DomainKeys Identified Mail) ajoute une signature cryptographique à chaque e-mail sortant, vérifiable par le serveur destinataire à partir de la clé publique publiée dans le DNS. DMARC (Domain-based Message Authentication, Reporting and Conformance) définit la politique à appliquer par les serveurs destinataires lorsque SPF ou DKIM échouent (aucune action, quarantaine ou rejet) et fournit des rapports sur les tentatives d'usurpation du domaine.

4. Le Bastion SSH — Point d'Accès d'Administration

Le bastion (ou jump server) est le point d'accès unique et contrôlé pour l'administration de l'ensemble des systèmes de l'infrastructure. Toute connexion SSH ou RDP vers un serveur quelconque doit impérativement transiter par le bastion : les administrateurs se connectent d'abord au bastion (depuis leur poste d'administration ou via VPN), puis rebondissent vers le serveur cible. Cette architecture interdit les connexions directes depuis les postes de travail vers les serveurs et concentre toute l'activité d'administration en un point unique, journalisé et contrôlé.

Un bastion moderne intègre plusieurs fonctionnalités de sécurité avancées. L'authentification multifacteur (MFA) est obligatoire pour toute connexion au bastion. L'enregistrement complet des sessions (session recording) capture tout ce que l'administrateur voit et fait pendant sa session — une fonctionnalité précieuse pour l'audit et l'investigation forensique. Le contrôle d'accès granulaire définit, pour chaque administrateur, les systèmes cibles auxquels il est autorisé à accéder depuis le bastion. Des solutions open source comme Teleport ou Apache Guacamole proposent ces fonctionnalités sous forme de plateformes web accessibles depuis un navigateur, sans client SSH spécifique à déployer sur les postes.

Chapitre 5 : Filtrage Applicatif et Mécanismes Complémentaires

1. Le WAF — Web Application Firewall

Un pare-feu réseau classique contrôle les flux au niveau des couches 3 et 4 (IP, port, protocole) mais est aveugle au contenu applicatif : une requête HTTPS vers le port 443 d'un serveur web est autorisée, que son contenu soit une requête légitime ou une tentative d'injection SQL. Le WAF (Web Application Firewall) comble cette lacune en analysant le contenu HTTP/HTTPS des requêtes et en bloquant celles qui correspondent aux patterns d'attaque applicatifs référencés dans l'OWASP Top 10.

Le WAF peut être déployé en mode inline (en coupure, avant le serveur web — il bloque activement les requêtes malveillantes) ou en mode détection (en écoute, il génère des alertes sans bloquer). Le mode inline est le mode opérationnel normal en production ; le mode détection est utilisé pendant la phase de calibrage initial pour identifier et corriger les faux positifs avant de passer en blocage. Les WAF open source de référence sont ModSecurity (intégrable à Nginx ou Apache) et Coraza. Les solutions cloud comme AWS WAF, Cloudflare WAF ou Azure Application Gateway WAF proposent des WAF managés particulièrement adaptés aux architectures cloud hybrides.

2. Le Proxy Filtrant Sortant

Le proxy filtrant est un serveur intermédiaire par lequel tout le trafic web sortant des utilisateurs (HTTP/HTTPS) est forcé, avant d'atteindre Internet. Son déploiement implique que les postes de travail soient configurés pour utiliser le proxy (via WPAD ou configuration manuelle) et que le pare-feu bloque tout trafic HTTP/HTTPS sortant ne transitant pas par le proxy. Cette configuration garantit que l'intégralité de la navigation web des utilisateurs est visible, filtrable et journalisable.

Les fonctionnalités d'un proxy filtrant moderne incluent le filtrage par catégorie de contenu (blocage des sites malveillants, des réseaux sociaux non autorisés, des plateformes de partage de fichiers), l'inspection SSL (HTTPS break and inspect — le proxy déchiffre le trafic HTTPS pour l'analyser, puis le rechiffre avant de le transmettre), la détection de malwares dans les téléchargements, et la journalisation complète de toutes les requêtes pour investigation forensique. L'inspection SSL nécessite le déploiement d'un certificat proxy dans le magasin de certificats de confiance de tous les postes, une opération réalisée via GPO dans les environnements Windows. Des solutions open source comme Squid restent très utilisées, complétées par des solutions commerciales comme Zscaler ou Netskope pour les architectures cloud-first.

3. L'IPS Péri-métrique

L'IPS (Intrusion Prevention System) est un équipement en coupure sur le flux réseau périmétrique qui analyse le contenu des paquets pour détecter et bloquer les signatures d'attaque connues. Contrairement au WAF, qui est spécialisé dans les attaques applicatives web, l'IPS couvre un spectre plus large : exploitations de vulnérabilités réseau, scans de ports, attaques par force brute, trafic de botnets, protocoles anormaux. Les IPS modernes

(Next-Generation IPS) intègrent également des capacités d'analyse comportementale pour détecter des anomalies non couvertes par les signatures.

Le principal risque de l'IPS est la génération de faux positifs qui bloqueraient du trafic légitime. La mise en production d'un IPS doit donc suivre une phase de calibrage en mode détection (IDS) pendant laquelle les signatures déclenchées sur le trafic de production sont analysées et les faux positifs identifiés sont ajustés (modification des seuils, exclusion de sources spécifiques) avant l'activation du mode prévention. Dans les architectures pare-feu NGFW (Fortinet FortiGate, Palo Alto, Cisco FTD), l'IPS est directement intégré au moteur du pare-feu, simplifiant le déploiement et la gestion.

4. La Gestion du Trafic Chiffré — Défi de l'Inspection TLS

La généralisation du chiffrement TLS — plus de 90 % du trafic web est aujourd'hui chiffré en HTTPS — crée un défi majeur pour les équipements de sécurité périmétrique. Un pare-feu, un IPS ou un WAF configurés pour inspecter le trafic sans déchiffrement ne voient que des tunnels TLS opaques : ils peuvent contrôler les métadonnées (IP, port, SNI) mais pas le contenu des requêtes. Les attaquants exploitent cette opacité pour exfiltrer des données ou communiquer avec leurs serveurs C2 via des connexions HTTPS indiscernables du trafic légitime.

L'inspection TLS (SSL inspection, break and inspect) est la technique permettant aux équipements de sécurité de déchiffrer, inspecter et rechiffrer le trafic TLS en transit. Côté sortant (trafic utilisateurs vers Internet), elle est réalisée par le proxy filtrant. Côté entrant (trafic Internet vers les services DMZ), elle est réalisée par le reverse proxy ou le pare-feu NGFW. Cette technique soulève des considérations de confidentialité (le proxy a accès au contenu déchiffré) et de conformité (certains flux, comme les communications bancaires ou médicales, peuvent être soumis à des restrictions légales limitant l'inspection), qui doivent être traitées dans la politique de sécurité de l'organisation.

Chapitre 6 : Vecteurs d'Attaque et Contre-mesures Périmètre

1. Attaques Ciblantes les Services Exposés

Les services hébergés en DMZ publique sont exposés en permanence aux tentatives d'exploitation. Les attaques par force brute ciblent les interfaces d'authentification des services exposés (formulaires web, SSH, RDP, VPN) avec des dictionnaires de mots de passe ou des combinaisons automatisées. La protection s'effectue par la limitation du débit de tentatives d'authentification (rate limiting), le verrouillage temporaire des comptes après un nombre défini d'échecs, le déploiement d'un WAF filtrant les requêtes d'authentification anormales, et l'obligation de MFA pour tous les accès distants.

L'exploitation de vulnérabilités applicatives est le vecteur le plus redouté : une faille non patchée dans un CMS, un serveur web ou une API exposée peut permettre à un attaquant d'exécuter du code arbitraire sur le serveur DMZ, lui ouvrant la possibilité d'un pivot vers le

réseau interne. La protection repose sur la gestion rigoureuse des correctifs (patch management), le scan de vulnérabilités régulier des services exposés (hebdomadaire au minimum), le déploiement d'un WAF pour filtrer les tentatives d'exploitation avant qu'elles n'atteignent l'application, et la réduction de la surface d'attaque (désactivation des modules et fonctionnalités non utilisés, suppression des pages d'administration accessibles publiquement).

2. Le Pivot depuis la DMZ — Vecteur Critique

Le pivot (ou lateral movement) depuis la DMZ vers le réseau interne est le scénario d'attaque le plus critique ciblant l'architecture périmétrique. Un attaquant ayant compromis un serveur DMZ cherche naturellement à progresser vers les actifs plus précieux du réseau interne. Il peut y parvenir de plusieurs façons : en exploitant une règle de filtrage trop permissive entre la DMZ et le LAN (flux autorisés au-delà du strict nécessaire), en abusant d'un compte de service utilisé par le serveur DMZ pour accéder aux serveurs internes (par exemple, un compte AD utilisé par l'application web pour interroger la base de données), en exploitant un service commun aux deux zones (DNS, NTP, SNMP mal configuré).

La contre-mesure fondamentale est l'isolation stricte de la DMZ : aucun flux ne doit être autorisé de la DMZ vers le LAN sans justification fonctionnelle précise et validée, et chaque flux autorisé doit être aussi restrictif que possible (IP source précise, IP destination précise, port unique). Les comptes de service utilisés par les applications DMZ pour accéder aux ressources internes doivent être dédiés, avec des droits minimaux (lecture seule sur la base de données si possible), et leurs mots de passe doivent être différents de ceux utilisés en interne. Le SIEM doit surveiller en temps réel toute connexion depuis les serveurs DMZ vers le réseau interne et alerter immédiatement sur tout flux non documenté dans la matrice.

3. Les Attaques DDoS sur le Périmètre

Les attaques par déni de service distribué (DDoS) visent à saturer les ressources du périmètre réseau (bande passante, sessions pare-feu, CPU des équipements) pour rendre les services inaccessibles. Elles se déclinent en plusieurs catégories : les attaques volumétriques (saturation de la bande passante par envoi de volumes massifs de trafic UDP ou ICMP), les attaques de protocole (exploitation des limites du protocole TCP — SYN flood — pour épuiser les tables de connexions des pare-feu), et les attaques applicatives (volume élevé de requêtes HTTP apparemment légitimes, ciblant la capacité de traitement des serveurs web — HTTP flood).

La protection anti-DDoS s'organise en deux niveaux. En amont du périmètre, les opérateurs télécom et les fournisseurs de transit proposent des services de scrubbing qui dévient le trafic d'attaque vers des centres de nettoyage avant qu'il n'atteigne l'infrastructure de l'organisation. Des solutions cloud comme Cloudflare, Akamai ou AWS Shield absorbent les attaques au niveau de leur réseau mondial de distribution. Au niveau périmétrique, les équipements anti-DDoS dédiés (F5 Silverline, Radware DefensePro, Arbor Networks) ou les fonctionnalités anti-DDoS intégrées aux pare-feu NGFW permettent de filtrer le trafic d'attaque local et de maintenir les services disponibles pour les utilisateurs légitimes.

Chapitre 7 : Évolution du Périmètre — Cloud, Télétravail et Zero Trust

1. La Dissolution du Périmètre Traditionnel

Le modèle périmétrique classique — réseau interne de confiance, séparé d'un Internet hostile par un mur de sécurité — est mis à l'épreuve par trois évolutions structurelles du paysage informatique. L'adoption du cloud computing déplace des charges de travail entières vers des environnements hors du périmètre physique de l'organisation : les données et les applications migrent vers AWS, Azure ou Google Cloud, où les équipements périmétriques traditionnels n'ont plus de prise directe. La généralisation du télétravail fait éclater le modèle géographique : les utilisateurs accèdent aux ressources depuis leur domicile, des espaces de coworking ou des hôtels, depuis des réseaux non maîtrisés et des équipements dont le niveau de sécurité est variable.

La supply chain numérique — intégration croissante des partenaires, fournisseurs et prestataires dans les processus métier via des accès API ou des connexions directes au SI — multiplie les points d'entrée potentiels au-delà du périmètre maîtrisé. La réponse à ces défis ne consiste pas à abandonner la sécurité périmétrique — elle reste fondamentale pour protéger les actifs on-premise — mais à la compléter par de nouvelles approches architecturales adaptées au monde hybride et distribué.

2. Le Modèle Zero Trust

Le Zero Trust (confiance zéro) est le modèle de sécurité qui répond à la dissolution du périmètre traditionnel. Son principe fondateur, formulé par John Kindervag de Forrester Research en 2010, se résume en une phrase : ne jamais faire confiance, toujours vérifier (Never Trust, Always Verify). Contrairement au modèle périmétrique qui accorde une confiance implicite à tout trafic interne, le Zero Trust considère que chaque accès à une ressource doit être authentifié, autorisé et chiffré, quelle que soit la localisation de l'utilisateur ou du système demandeur — y compris à l'intérieur du réseau physique de l'organisation.

La mise en œuvre du Zero Trust repose sur plusieurs piliers complémentaires. L'identité forte remplace le réseau comme principal critère d'autorisation : l'accès est accordé non pas parce que l'utilisateur est sur le réseau interne, mais parce qu'il a prouvé son identité (MFA), que son poste est conforme (gestion des endpoints), et que son accès est expressément autorisé pour la ressource demandée. La micro-segmentation remplace la segmentation en zones larges par une segmentation granulaire des flux entre chaque application ou service, limitant drastiquement les possibilités de déplacement latéral même depuis l'intérieur du réseau. L'accès au moindre privilège est appliqué en continu et réévalué à chaque session, pas seulement au moment de l'authentification initiale.

3. SASE — Sécurité Périmétrique dans le Cloud

Le SASE (Secure Access Service Edge), concept introduit par Gartner en 2019, propose de fusionner les fonctions de réseau (SD-WAN) et de sécurité (proxy, WAF, CASB, Zero Trust Network Access) dans une plateforme cloud unique, consommée comme un service. L'idée est de déplacer le périmètre de sécurité vers le cloud, au plus proche des utilisateurs et des

données — qu'ils soient au bureau, en télétravail ou en déplacement — plutôt que de forcer tout le trafic à transiter par un équipement physique centralisé en entreprise.

Les bénéfices du SASE sont significatifs dans un contexte de travail hybride : les utilisateurs en télétravail bénéficient du même niveau de filtrage et de sécurité que les utilisateurs au bureau, sans VPN traditionnel ralentissant les connexions. Les applications SaaS (Microsoft 365, Salesforce, ServiceNow) sont accédées directement depuis le cloud, avec inspection de sécurité réalisée par la plateforme SASE sans détour par le datacenter de l'entreprise. Les fournisseurs leaders du SASE sont Zscaler, Netskope, Palo Alto Prisma Access et Cloudflare One. La DMZ et la sécurité périmétrique on-premise restent néanmoins indispensables pour les actifs qui ne peuvent pas migrer vers le cloud — systèmes industriels, données ultra-sensibles, systèmes legacy.

Chapitre 8 : Cas Pratique — Conception d'une Architecture DMZ

1. Présentation du Contexte

RetailGroup SA est une enseigne de distribution de 1 200 salariés, exploitant un site e-commerce générant 30 % de son chiffre d'affaires. Le site web est actuellement hébergé directement sur un serveur connecté au réseau interne de l'entreprise, sans DMZ. Un audit de sécurité récent a identifié cette architecture comme une vulnérabilité critique : une compromission du serveur web donnerait un accès direct au réseau interne hébergeant les serveurs ERP, les bases de données clients et le système de caisse. La direction a mandaté le RSSI pour concevoir et mettre en œuvre une architecture DMZ sécurisée dans un délai de 3 mois.

L'infrastructure concernée comprend : un serveur web Nginx hébergeant le site e-commerce (accès public, fort volume de trafic), un serveur d'application Python/Django (accès depuis le serveur web uniquement), une base de données PostgreSQL (accès depuis l'application uniquement), un serveur Exchange pour la messagerie interne (accès interne + accès depuis Internet pour les appareils mobiles), un Active Directory, et 80 postes de travail utilisateurs. Le pare-feu actuel est un Fortinet FortiGate 100F avec quatre interfaces disponibles.

2. Phase 1 — Conception de l'Architecture

L'architecture retenue est une DMZ à un pare-feu multi-interface (compromis entre sécurité et budget), avec une évolution prévue vers une architecture à deux pare-feu dans 18 mois. Le FortiGate 100F est configuré avec quatre interfaces : WAN (connexion Internet), DMZ_PUB (DMZ publique — 172.16.10.0/24), DMZ_PRIV (DMZ privée — 172.16.20.0/24) et LAN (réseau interne — 192.168.0.0/16).

La répartition des systèmes entre les zones est définie ainsi. En DMZ publique : le reverse proxy Nginx (172.16.10.10) qui reçoit tout le trafic HTTPS entrant, la passerelle e-mail Exchange Edge (172.16.10.11) pour le filtrage des e-mails entrants/sortants, et un serveur

DNS public (172.16.10.12) ne gérant que la zone DNS externe. En DMZ privée : le serveur d'application Python/Django (172.16.20.10) accessible uniquement depuis le reverse proxy, et un bastion Teleport (172.16.20.11) pour l'administration de l'ensemble des serveurs. En zone serveurs interne : la base de données PostgreSQL (192.168.10.5), le serveur Exchange principal (192.168.10.6) et l'Active Directory (192.168.10.1).

3. Phase 2 — Matrice de Flux et Règles de Filtrage

La matrice de flux est rédigée en collaboration avec les équipes IT et les responsables métier pour identifier l'ensemble des communications nécessaires. Les flux identifiés sont les suivants : Internet vers Reverse Proxy DMZ_PUB sur TCP/443 (navigation e-commerce), Internet vers Exchange Edge DMZ_PUB sur TCP/25 (e-mail entrant), Reverse Proxy vers Serveur App DMZ_PRIV sur TCP/8000 (requêtes applicatives), Serveur App DMZ_PRIV vers PostgreSQL LAN sur TCP/5432 (accès base de données), LAN vers Internet via proxy sur TCP/443 (navigation utilisateurs), et Bastion DMZ_PRIV vers tous les serveurs sur TCP/22.

La règle de sécurité fondamentale est explicitement formulée et documentée : tout flux depuis DMZ_PUB vers LAN ou depuis DMZ_PUB vers DMZ_PRIV est interdit, à l'exception du flux Reverse Proxy vers Serveur App (DMZ_PUB vers DMZ_PRIV uniquement sur TCP/8000). Cette règle garantit qu'une compromission du reverse proxy ou de la passerelle e-mail ne permet pas d'accéder directement au réseau interne ou au serveur d'application. Le WAF ModSecurity est déployé sur le reverse proxy avec le jeu de règles OWASP Core Rule Set (CRS) en mode détection pendant deux semaines, puis en mode blocage après calibrage des faux positifs.

4. Phase 3 — Mise en Œuvre et Bilan

La migration du serveur web vers l'architecture DMZ est réalisée en dehors des heures de pointe, avec un plan de rollback documenté. Le déploiement du reverse proxy en frontal, avec terminaison TLS et redirection vers le serveur d'application en DMZ privée, est validé fonctionnellement par l'équipe e-commerce avant la coupure de l'ancien serveur. Les logs du FortiGate commencent à alimenter le SIEM Wazuh existant via Syslog, avec une règle d'alerte dédiée sur tout flux détecté depuis la DMZ vers le LAN hors règles autorisées.

Deux semaines après le déploiement, le WAF en mode détection a identifié 847 tentatives d'injection SQL sur les formulaires du site e-commerce et 234 tentatives de path traversal — toutes passant jusqu'alors sans détection dans l'ancienne architecture. Le mode blocage est activé après suppression de 12 faux positifs liés à des requêtes légitimes contenant des caractères SQL dans les champs de recherche produit. La surface d'attaque du réseau interne est significativement réduite : le serveur d'application n'est plus accessible directement depuis Internet, la base de données n'est plus accessible depuis la DMZ publique, et tout flux anormal entre zones génère une alerte SIEM.

Synthèse Générale du Module

Ce cours vous a conduit depuis les fondements conceptuels de la sécurité périmétrique jusqu'à la mise en œuvre concrète d'une architecture DMZ dans un contexte d'entreprise réel, en passant par la conception des zones de sécurité, la gestion des flux interzones, la sécurisation des services exposés, les mécanismes de filtrage applicatif et les évolutions architecturales induites par le cloud et le Zero Trust.

Trois grandes leçons synthétisent l'ensemble du cours. La première est que l'architecture précède toujours la configuration. Une DMZ mal conçue — zones mal définies, flux non documentés, services mal positionnés — ne peut pas être compensée par une configuration pare-feu sophistiquée. Investir du temps dans la conception de l'architecture, la rédaction de la matrice de flux et la formalisation des zones de sécurité est la condition préalable à tout déploiement technique efficace. Une règle de pare-feu sans matrice de flux de référence est une règle dont on ne peut pas vérifier la cohérence.

La deuxième leçon est que la sécurité périmétrique est vivante, pas statique. Les flux réseau évoluent avec le SI : de nouvelles applications sont déployées, de nouveaux partenaires sont intégrés, de nouveaux services cloud sont adoptés. Chaque évolution du SI doit impérativement passer par un processus de validation sécurité qui met à jour la matrice de flux et les règles de filtrage. Une matrice de flux non maintenue perd sa valeur d'audit en quelques mois ; un pare-feu dont les règles ne correspondent plus aux flux réels est un équipement de sécurité qui protège contre une topologie qui n'existe plus.

La troisième leçon est que la sécurité périmétrique, aussi robuste soit-elle, ne peut pas être la seule ligne de défense. Elle doit s'inscrire dans une stratégie de défense en profondeur : les équipements internes doivent être patchés et durcis (car le périmètre peut être franchi), le SIEM doit superviser les flux interzones (car des flux autorisés peuvent être détournés), et les utilisateurs doivent être sensibilisés (car le phishing contourne le périmètre réseau). Le périmètre est une couche de défense indispensable, pas une garantie absolue.

Glossaire

Terme	Définition
ACL	Access Control List — liste ordonnée de règles de filtrage appliquées sur un équipement réseau (routeur, switch de niveau 3) pour autoriser ou interdire les flux selon des critères IP, port et protocole.
Bastion	Équipement ou machine renforcé servant de point d'accès unique et contrôlé pour l'administration des systèmes d'une zone sécurisée, typiquement via SSH ou RDP avec authentification forte.
CASB	Cloud Access Security Broker — solution interposée entre les utilisateurs et les services cloud pour appliquer des politiques de sécurité, de conformité et de visibilité sur l'usage du cloud.
Defense in Depth	Stratégie de sécurité superposant plusieurs couches de protection indépendantes, de sorte que la compromission d'une couche ne suffise pas à compromettre l'ensemble du système.
Diode réseau	Équipement matériel garantissant un flux de données strictement unidirectionnel entre deux réseaux, physiquement impossible à inverser, utilisé pour protéger les réseaux OT/SCADA.
DMZ	DeMilitarized Zone — zone réseau intermédiaire entre Internet et le réseau interne, hébergeant les services exposés publiquement tout en les isolant du réseau privé.
Dual-homed	Qualifie un équipement ou serveur possédant deux interfaces réseau connectées à deux zones différentes, pouvant servir de passerelle entre elles.
IDS / IPS	Intrusion Detection System / Intrusion Prevention System — systèmes analysant le trafic réseau pour détecter (IDS) ou bloquer activement (IPS) les attaques et comportements suspects.
Lateral movement	Technique par laquelle un attaquant ayant compromis un système se déplace vers d'autres systèmes du réseau, en exploitant les relations de confiance et les accès disponibles.
mTLS	Mutual TLS — variante du protocole TLS dans laquelle le client et le serveur s'authentifient mutuellement par certificat, garantissant l'identité des deux extrémités de la connexion.
NAT	Network Address Translation — mécanisme traduisant les adresses IP privées en adresses publiques (et vice versa), masquant la topologie du réseau interne depuis Internet.
Périmètre réseau	Frontière logique et physique délimitant le réseau interne d'une organisation de l'extérieur, gardée par les équipements de sécurité périmétrique (pare-feu, IPS, proxy).
Proxy filtrant	Serveur intermédiaire par lequel tout le trafic web sortant des utilisateurs est forcé, permettant d'analyser, filtrer et journaliser les requêtes HTTP/HTTPS.
Reverse proxy	Serveur intermédiaire placé devant les serveurs web internes, recevant les requêtes des clients externes et les redistribuant aux serveurs d'application, tout en masquant leur topologie.
VLAN	Virtual Local Area Network — segmentation logique d'un réseau physique permettant d'isoler des groupes d'équipements en domaines de broadcast distincts, sans câblage séparé.

WAF	Web Application Firewall — solution de filtrage applicatif spécialisée dans la protection des applications web contre les attaques OWASP Top 10 (injection SQL, XSS, CSRF, etc.).
-----	---